📅 DOSSIER DE CONCEPTION MENSUEL — IA-INSIGHT

SEPTEMBRE 2026 — MOIS 3 / 4

Gouvernance IA & Sécurité RGPD

Implémenter la couche de gouvernance IA (audit trail, PII masking, modèles versionnés) et atteindre la conformité RGPD complète avec le droit à l'oubli et la portabilité des données.

🤖 Gouvernance IA | 🔒 OWASP LLM Top 10 | 🇪🇺 RGPD / DPIA | 📋 Audit Trail | 🕵️ PII Masking | 📊 Token Budget

SOCIÉTÉ	SPRINTS	DURÉE	STATUT	ÉQUIPE
IA-INSIGHT	S3 + S4	4 semaines	📋 Planifié	2 devs + 1 SecOps

Sommaire

#	Section
1	Contexte & Besoin métier
2	Solution proposée & Périmètre
3	Architecture technique
4	Roadmap globale — 8 sprints / 4 mois
5	Sprints du mois — Septembre 2026
6	Liste des bugs & dette technique
7	Sprint Review & Rétrospective

SECTION 1

Contexte & Besoin métier

Le problème des ESN aujourd'hui

Les ESN et cabinets de conseil IT gèrent des dizaines à des centaines de consultants disséminés chez leurs clients. Chaque mois, ce modèle génère une charge administrative considérable :

3h
PERDUES PAR CONSULTANT/MOIS EN ADMIN

23%
NOTES DE FRAIS AVEC ERREURS

8j
DÉLAI MOYEN FACTURATION POST-CRA

Processus	Situation actuelle	Impact
Notes de frais	Saisie manuelle Excel, scan PDF par email	Erreurs, pièces perdues, retards remboursement
CRA mensuel	Feuille Excel partagée ou formulaire papier	Retards validation → retards facturation client
Facturation client	Factures Word/Excel manuelles	Risques TVA, numérotation incohérente
Gestion congés	Email ou HR tool déconnecté des outils métier	Calcul frais km erroné si absences non remontées
Visibilité manager	Aucun tableau de bord temps réel	Arbitrages retardés, perte de contexte

Besoins consultant

- → Saisir une note de frais en langage naturel

Besoins manager / admin

- → Valider/refuser frais et CRA en 1 clic

- → Photographier un justificatif → OCR automatique
- → Frais km avec exclusion automatique absences/congés
- → Soumettre son CRA depuis n'importe quel appareil
- → Notifications temps réel sur les décisions admin
- → Génération automatique de factures PDF post-CRA
- → Tableau de bord global : frais, CRA, factures
- → Console multi-tenant : piloter plusieurs ESN
- → Conformité RGPD & audit trail LLM

SECTION 2

Solution proposée & Périmètre

> **Vision produit :** Plateforme SaaS multi-tenant d'automatisation administrative pour ESN. L'utilisateur parle à un assistant IA en français naturel — il s'occupe du reste.

✅ Dans le périmètre

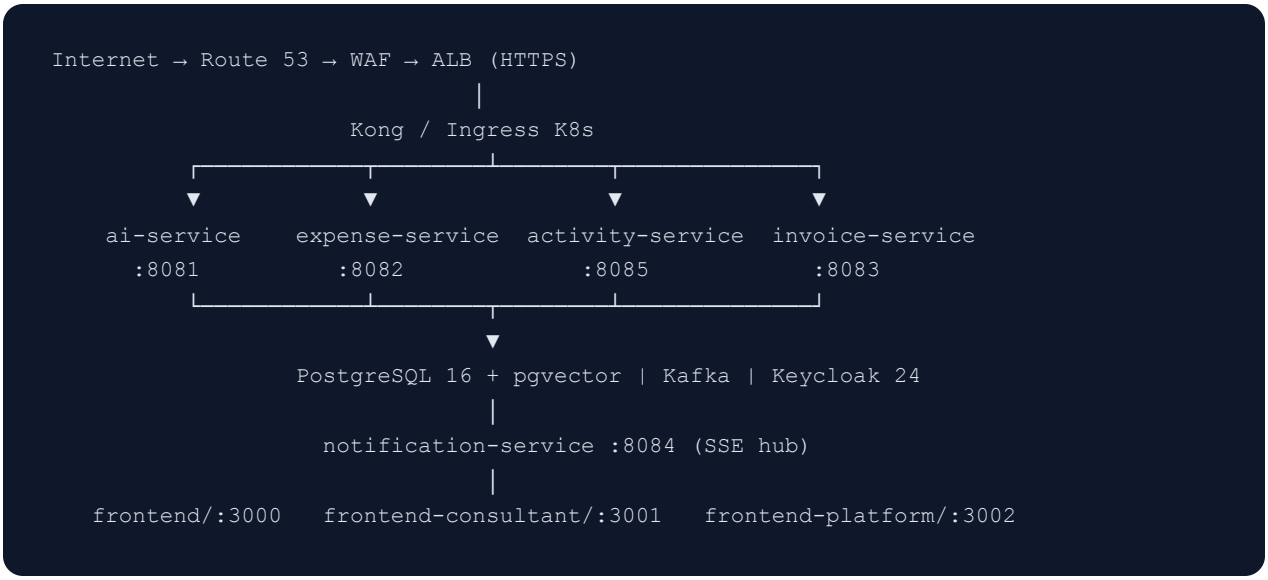
- ✓ Notes de frais — saisie libre, OCR, frais km
- ✓ CRA mensuel — workflow BROUILLON→SOUMIS→VALIDÉ
- ✓ Congés CP/RTT — demandes & solde
- ✓ Facturation — PDF & Excel client
- ✓ Notifications SSE temps réel
- ✓ Pipeline RAG pgvector + LLM Groq/OpenAI
- ✓ Multi-tenant Keycloak realm-per-tenant
- ✓ Gouvernance IA (audit, PII masking, token budget)
- ✓ Conformité RGPD (droit à l'oubli, portabilité)
- ✓ AWS Production (EKS, RDS, MSK, DR)

Stack technique

Couche	Technologie
LLM principal	Groq — llama-3.1-8b + gpt-oss-120b
LLM fallback	OpenAI gpt-4.1-mini (circuit breaker)
Embeddings	OpenAI text-embedding-3-large
DB + Vector	PostgreSQL 16 + pgvector
Auth	Keycloak 24 realm-per-tenant
Messaging	Apache Kafka KRaft
Backend	Spring Boot 3.3 / Java 21
Cloud	AWS EKS + RDS + MSK

SECTION 3

Architecture technique



Multi-tenant

Chaque organisation = 1 realm Keycloak. `TenantFilter` extrait le realm du JWT → `TenantContext` (ThreadLocal UUID). Toutes les requêtes JPA filtrent par `tenant_id`.

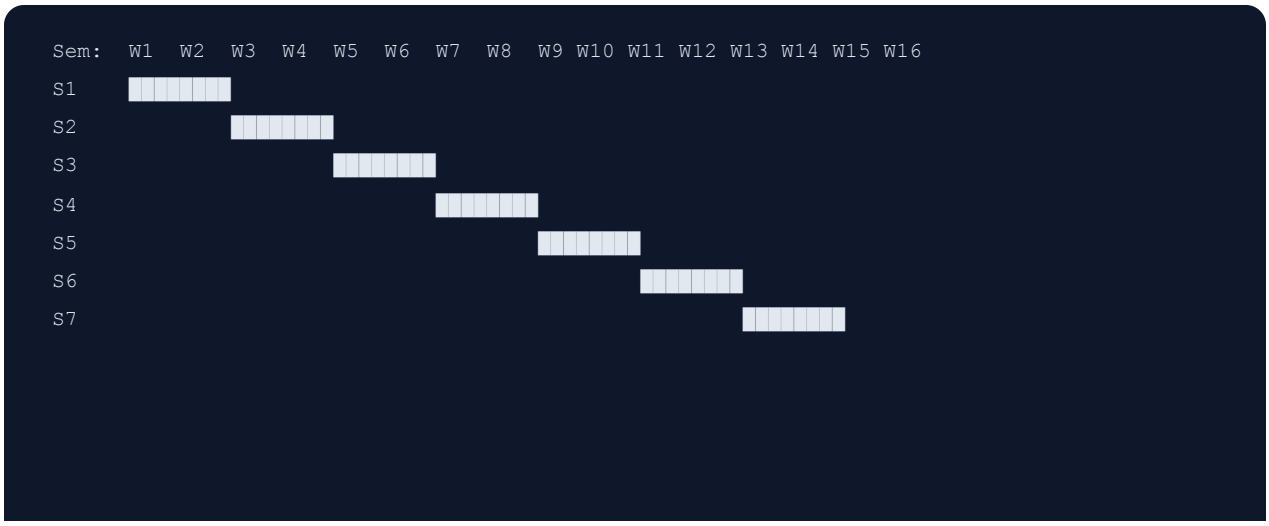
Résilience LLM

Groq primaire. Sur 5 échecs / 10 appels → circuit ouvert resilience4j → bascule immédiate OpenAI gpt-4.1-mini. Refermeture 30s. SSE broadcast via Kafka (group-id unique par pod `${HOSTNAME}`).

SECTION 4

Roadmap globale — 8 Sprints / 4 Mois

Sprint	Mois	Thème	Valeur livrée
S1	Juillet	Consolidation architecture + Kong	Architecture propre, routing vers chaque service
S2	Juillet	UX Design System & 3 frontends	Expérience unifiée, mobile WCAG AA
S3	Août	Gouvernance IA — Audit, PII Masking	0 PII vers LLM, traçabilité complète
S4	Août	Sécurité RGPD & Versioning modèles	DPIA validé, droit à l'oubli
S5	Septembre	Facturation end-to-end	Cycle CRA → Facture → Paiement
S6	Septembre	Observabilité & SLA	Grafana, alerting, runbooks
S7	Octobre	AWS Architecture & Terraform	EKS, RDS, MSK, Secrets Manager
S8	Octobre	Production Deployment & Go-Live	AWS prod, client pilote, SLA 99.9%




S8
Juillet
Août
Septembre
Octobre

CONTEXTE DU MOIS

Pourquoi Gouvernance IA & Sécurité maintenant ?

Après la consolidation technique de Juillet-Août, Septembre est consacré, pour IA-INSIGHT, aux deux axes non-fonctionnels les plus critiques avant d'aller en production réelle : la **gouvernance des modèles IA** et la **conformité réglementaire RGPD**. Ces sujets ne peuvent pas être traités en fin de projet — ils structurent la confiance des clients ESN.

> **Risque réglementaire :** Sans audit trail LLM et sans mécanisme de droit à l'oubli, la plateforme ne peut pas être vendue à des ESN opérant sous contrat avec des grandes entreprises (banques, assurances, secteur public) qui exigent ces garanties contractuellement.

0	0	~12
TRACES LLM ACTUELLEMENT LOGGÉES	MÉCANISMES DROIT À L'OUBLI	CONTRÔLES OWASP LLM EN PLACE

S3

Gouvernance IA — Audit, PII Masking & Token Budget

Semaines 5-6 · Septembre 2026 · Responsable : Tech Lead IA + DPO

Cadre de gouvernance IA à implémenter

La gouvernance IA couvre 5 piliers : traçabilité, confidentialité des données, contrôle des coûts, versioning des modèles, et incident response. Ce sprint livre les 3 premiers.

Pilier	Statut avant S3	Objectif S3
Traçabilité	❌ Aucune	Table llm_audit_log complète
Confidentialité PII	⚠️ Log masking partiel	Masquage avant envoi LLM
Contrôle coûts	❌ Aucun	Token budget par tenant/mois
Versioning modèles	❌ Aucun	Planifié S4
Incident response	❌ Aucun	Planifié S4

Schéma de la table llm_audit_log

Colonne	Type	Description
`id`	UUID PK	Identifiant unique de l'appel
`tenant_id`	UUID FK	Tenant concerné (isolation)

Colonne	Type	Description
`user_email`	VARCHAR(150)	Consultant ou admin ayant déclenché l'appel
`session_id`	VARCHAR(64)	Session browser (pour grouper les échanges)
`intent`	VARCHAR(50)	Intent classifié (create_expense, rag_query…)
`model_used`	VARCHAR(80)	ID exact du modèle Groq/OpenAI utilisé
`prompt_hash`	VARCHAR(64)	SHA-256 du prompt (sans PII) — non réversible
`tokens_input`	INTEGER	Tokens consommés en entrée
`tokens_output`	INTEGER	Tokens générés en sortie
`latency_ms`	INTEGER	Temps de réponse LLM en ms
`fallback_used`	BOOLEAN	true si OpenAI fallback déclenché
`guard_blocked`	BOOLEAN	true si PromptGuard a bloqué
`created_at`	TIMESTAMPTZ	Horodatage UTC

PII Masking — règles à appliquer

- → Emails : remplacer par `[EMAIL]` avant envoi LLM
- → IBAN/BIC : remplacer par `[IBAN]`
- → Noms propres : remplacer par `[NOM]` (via NER ou regex)
- → Numéros de téléphone : `[TEL]`

Token Budget par tenant

- ✓ Table `tenant_token_budget` : budget_mensuel, tokens_consommés, alerte_seuil
- ✓ Alerte à 80% du budget → notification admin platform
- ✓ Blocage à 100% → HTTP 429 "Budget LLM épuisé"
- ✓ Reset automatique le 1er du mois
- ✓ Dashboard platform_admin : consommation par tenant en temps réel
- ✓ Default budget : 500 000 tokens/mois/tenant

- Adresses IP : `[IP]`
- Le prompt masqué est loggué — pas l'original
- Le prompt_hash = SHA-256(prompt_original) pour audit sans exposition

User stories Sprint 3

- En tant que platform_admin, je consulte un dashboard montrant la consommation LLM (tokens, coût estimé, latence p95) par tenant et par mois
- En tant que DPO, je certifie qu'aucun email, IBAN ou nom propre n'est transmis aux APIs LLM externes (Groq/OpenAI)
- En tant que platform_admin, je fixe un budget de tokens mensuel par tenant et reçois une alerte quand 80% est atteint
- En tant qu'auditeur, je peux exporter le log de tous les appels LLM d'un tenant sur une période donnée (format CSV)
- En tant que consultant, si le budget LLM de mon organisation est épuisé, je reçois un message explicite (pas une erreur 500)

Definition of Done — Sprint 3

- ✓ Migration Flyway : table llm_audit_log créée avec index sur (tenant_id, created_at)
- ✓ LLMAIClient enrichi : log de chaque appel dans llm_audit_log après réponse
- ✓ PiiMasker.java : regex + masquage appliqué à tous les prompts entrants
- ✓ TenantTokenBudgetService : vérification avant chaque appel LLM
- ✓ Dashboard platform_admin : graphes tokens/coût/latence par tenant
- ✓ Test : envoyer "mon email est test@example.com" → vérifier que [EMAIL] est loggué

S4 Sécurité avancée, RGPD & Versioning des modèles

Semaines 7-8 · Septembre 2026 · Responsable : Tech Lead Sécurité + DPO

RGPD — Droits des personnes à implémenter

Droit RGPD	Article	Implémentation technique	Délai légal
Droit d'accès	Art. 15	GET /privacy/export → ZIP (expenses, CRA, frais, profil)	30 jours
Droit à l'oubli	Art. 17	DELETE /privacy/erase → anonymisation (pas suppression des factures légales)	30 jours
Portabilité	Art. 20	Export JSON structuré de toutes les données personnelles	30 jours
Rectification	Art. 16	PUT /consultants/profiles/{id} — déjà disponible	Immédiat
Opposition au profiling	Art. 21	Flag `opt_out_llm_training` sur tenant	Immédiat

Model Versioning & Incident Response

- → Table `llm_model_registry` : model_id, provider, version, deployed_at, deprecated_at, replacement
- → Rollback automatique si un modèle génère >5% d'erreurs JSON en 10 min
- → Runbook "LLM Incident" : détection → confinement → rollback → post-mortem

- ✓ DPIA (Data Protection Impact Assessment) rédigé et validé DPO
- ✓ Registre des traitements mis à jour
- ✓ Politique de rétention des données : logs = 90j, données métier = 7 ans (légal)
- ✓ Chiffrement AES-256 at-rest sur les colonnes sensibles (IBAN, token LLM)

→ Alerte PagerDuty (ou équivalent) si fallback Groq→OpenAI dure >15 min

Checklist sécurité OWASP LLM Top 10

#	Menace OWASP LLM	Statut	Action S4
LLM01	Prompt Injection	✓ Couvert	Renforcer les patterns injection multilingues
LLM02	Insecure Output Handling	✓ Couvert	LlmJsonValidator en place
LLM03	Training Data Poisoning	Partiel	Fact-checking sur les montants (RAGService)
LLM04	Model Denial of Service	Partiel	Token budget S3 + rate limiting
LLM05	Supply Chain Vulnerabilities	✗ Absent	SBOM + OWASP Dependency Check en CI
LLM06	Sensitive Info Disclosure	Partiel	PII Masking S3 + log masking
LLM07	Insecure Plugin Design	✓ N/A	Pas de plugins LLM externes
LLM08	Excessive Agency	✓ Couvert	LLM ne peut pas déclencher d'actions directes
LLM09	Overreliance	✗ Absent	Avertissement UI sur les extractions LLM
LLM10	Model Theft	✓ N/A	Modèles tiers (Groq/OpenAI) — non applicable

Definition of Done — Sprint 4

✓ Endpoint GET /privacy/export → ZIP téléchargeable en < 30s

- ✓ Endpoint DELETE /privacy/erase → anonymisation vérifiable en base
- ✓ DPIA signé et archivé dans docs/DPIA-2026.pdf
- ✓ OWASP Dependency Check : 0 CVE critique dans le rapport CI
- ✓ Table llm_model_registry créée avec l'historique des modèles utilisés
- ✓ Runbook LLM Incident rédigé dans docs/RUNBOOK-LLM.md
- ✓ Avertissement "données extraites par IA — à vérifier" visible sur les notes de frais OCR

SUIVI QUALITÉ

Liste des bugs & dette technique à traiter

Audit de maturité prod mené en parallèle des Sprints 3 & 4 (sécurité réseau, résilience Kafka, exposition de logs). Chaque ligne est rattachée au sprint responsable de sa correction.

#	Bug / Dette technique	Sévérité	Sprint	Statut
1	Secrets K8s en clair — placeholders `$OPENAI_API_KEY`, `$AI_CORE_ADMIN_KEY`, `$KEYCLOAK_ADMIN_PASSWORD` non résolus dans `ai-service/deploy/k8s/secret.yaml`	Critique	S4	🔴 Ouvert — injection des vraies valeurs en cluster requise
2	Absence de NetworkPolicy sur 4 des 5 microservices (seul ai-service isolé réseau)	Élevée	S3	🟢 Corrigé — branche `sprint3`
3	Aucun HorizontalPodAutoscaler ni PodDisruptionBudget sur les 5 services — pas de scaling auto, downtime possible en rolling update	Élevée	S3	🟢 Corrigé — branche `sprint3`
4	`ReasoningController` loggue le `ReasoningResult` complet en clair (OWASP LLM01 — divulgation d'information sensible)	Moyenne	S3	🟢 Corrigé — branche `sprint3`
5	`LLMAIClient` loggue le baseUrl du LLM fallback en clair au démarrage	Faible	S3	🟢 Corrigé — branche `sprint3`
6	Kafka `platform.notifications` : aucun retry ni Dead-Letter Topic — message perdu définitivement en cas d'erreur non-transiente ; auto-commit actif même en cas d'échec de traitement	Élevée	S3	🟡 Partiel — retry + DLT ajoutés (branche `sprint3`), passage en ack manuel restant

#	Bug / Dette technique	Sévérité	Sprint	Statut
7	invoice-service : appel HTTP synchrone sans file d'attente — une demande de facture est perdue si le service est indisponible au moment de l'appel	Moyenne	S4	🔴 Ouvert — trade-off documenté (docs/KAFKA.md), à réévaluer si le volume augmente
8	Route Kong `/invoices` sans plugin jwt/rate-limiting/cors, contrairement à la route `ai-core`	Élevée	S3	🔴 Ouvert — à vérifier et corriger

> **Priorité de correction avant Go/No-Go Octobre :** les items #1 et #8 sont bloquants pour une mise en production réelle (secrets non résolus + gateway sans protection) et doivent être traités avant la fin du Sprint 4.

FIN DE MOIS

Sprint Review & Rétrospective Septembre

Démos à préparer

- → Envoyer "mon IBAN est FR76 1234 5678" → montrer que [IBAN] est loggué, pas la valeur réelle
- → Atteindre 80% du budget token → montrer l'alerte admin
- → Déclencher l'export RGPD d'un consultant → télécharger le ZIP
- → Montrer le dashboard gouvernance IA avec graphes par tenant

KPIs du mois

- ✓ 100% des appels LLM tracés dans llm_audit_log
- ✓ 0 PII transmis aux APIs externes (validation audit)
- ✓ DPIA validé DPO
- ✓ OWASP LLM : 8/10 risques couverts (vs 4/10 avant S3)